



Recon Findings Summary

Prepared by: Luigi Falconi, CISO

Chief Information Security Officer

July 24th, 2025



security@falconi.com

220 Gardenpoint Plaza, Suite 205, Newark, NJ 0710
(973) 555-1490

Potential Exposures

Open Ports

Using Wireshark and Nmap, we were able to detect frequent use of Port 4444.

Port 4444 is open on one of Falconi's public-facing servers. This port is commonly used for remote shells and can be exploited by attackers if not monitored or protected.

Open ports are commonly exploited through Denial of Service (DoS) attacks, man-in-the-middle-attacks, and more.

Open ports can also be used as entry points to launch attacks like SQL injection and cross site request forgery.

One of Falconi's public servers has **Port 4444 open**, which is often used by hackers to run **remote access tools** like backdoors or control panels. If this port isn't protected, someone from outside could use it to take control of the server.

Open ports like this are commonly used in cyberattacks. They can allow things like:

- **Denial of Service (DoS)** attacks that flood the system and shut it down
- **Man-in-the-middle attacks** where someone secretly watches or changes data being sent
- **Launching other attacks** like stealing passwords, injecting bad code, or gaining more access

This issue could be tied to:

- **An insecure admin area** that's easy to find and exploit
- **Insider threats**, such as someone inside the company using this open port in a harmful way

Risk Identification

- **Primary Risk ID: R-8 – Misconfigured Network Infrastructure**



security@falconi.com

220 Gardenpoint Plaza, Suite 205, Newark, NJ 0710
(973) 555-1490

- Justification: An open port may provide attackers with unauthorized access to internal systems and data.
- **Possible: R-4 – Insider Threat**
 - If internal misuse of this port is suspected or plausible.

Real-World Impact

WannaCry ransomware exploited an open port (TCP 445) and a Windows vulnerability called EternalBlue to spread rapidly across networks in 2017. The malware used this open port to remotely install itself on unpatched machines, encrypt data, and lock out users worldwide within minutes.

Supporting Attachments

3	2025-07-09 12:58:53.810650	10.129.43.29	10.129.43.4	TCP	66	50612 → 4444	[SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
4	2025-07-09 12:58:53.810705	10.129.43.4	10.129.43.29	TCP	66	4444 → 50612	[SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM WS=128
5	2025-07-09 12:58:53.810850	10.129.43.29	10.129.43.4	TCP	60	50612 → 4444	[ACK] Seq=1 Ack=1 Win=2102272 Len=0
6	2025-07-09 12:58:53.881232	10.129.43.29	10.129.43.4	TCP	178	50612 → 4444	[PSH, ACK] Seq=1 Ack=1 Win=2102272 Len=121
7	2025-07-09 12:58:53.881278	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=1 Ack=122 Win=64128 Len=0
8	2025-07-09 12:59:04.486021	10.129.43.4	10.129.43.29	TCP	61	4444 → 50612	[PSH, ACK] Seq=1 Ack=122 Win=64128 Len=7
9	2025-07-09 12:59:04.555521	10.129.43.29	10.129.43.4	TCP	60	50612 → 4444	[ACK] Seq=122 Ack=8 Win=2102272 Len=0
10	2025-07-09 12:59:04.555556	10.129.43.29	10.129.43.4	TCP	110	50612 → 4444	[PSH, ACK] Seq=122 Ack=8 Win=2102272 Len=56
11	2025-07-09 12:59:04.555570	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=8 Ack=178 Win=64128 Len=0
12	2025-07-09 12:59:09.013100	10.129.43.4	10.129.43.29	TCP	63	4444 → 50612	[PSH, ACK] Seq=8 Ack=178 Win=64128 Len=9
13	2025-07-09 12:59:09.021950	10.129.43.29	10.129.43.4	TCP	64	50612 → 4444	[PSH, ACK] Seq=178 Ack=17 Win=2102272 Len=10
14	2025-07-09 12:59:09.021973	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=17 Ack=188 Win=64128 Len=0
15	2025-07-09 12:59:09.072232	10.129.43.29	10.129.43.4	TCP	254	50612 → 4444	[PSH, ACK] Seq=188 Ack=17 Win=2102272 Len=200
16	2025-07-09 12:59:09.072268	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=17 Ack=388 Win=64128 Len=0
17	2025-07-09 12:59:09.072421	10.129.43.29	10.129.43.4	TCP	841	50612 → 4444	[PSH, ACK] Seq=388 Ack=17 Win=2102272 Len=787
18	2025-07-09 12:59:09.072427	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=17 Ack=1175 Win=64128 Len=0
19	2025-07-09 12:59:15.395340	10.129.43.4	10.129.43.29	TCP	61	4444 → 50612	[PSH, ACK] Seq=17 Ack=1175 Win=64128 Len=7
20	2025-07-09 12:59:15.436636	10.129.43.29	10.129.43.4	TCP	60	50612 → 4444	[PSH, ACK] Seq=1175 Ack=24 Win=2102272 Len=14
21	2025-07-09 12:59:15.436689	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=24 Ack=1189 Win=64128 Len=0
22	2025-07-09 12:59:16.390840	10.129.43.4	10.129.43.29	TCP	58	4444 → 50612	[PSH, ACK] Seq=24 Ack=1189 Win=64128 Len=4
23	2025-07-09 12:59:16.456886	10.129.43.29	10.129.43.4	TCP	60	50612 → 4444	[ACK] Seq=1189 Ack=28 Win=2102272 Len=0
24	2025-07-09 12:59:16.456923	10.129.43.4	10.129.43.29	TCP	255	50612 → 4444	[PSH, ACK] Seq=1189 Ack=28 Win=2102272 Len=201
25	2025-07-09 12:59:16.456938	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=28 Ack=1390 Win=64128 Len=0
26	2025-07-09 12:59:16.457083	10.129.43.29	10.129.43.4	TCP	314	50612 → 4444	[PSH, ACK] Seq=1390 Ack=28 Win=2102272 Len=260
27	2025-07-09 12:59:16.457088	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=28 Ack=1650 Win=64128 Len=0
28	2025-07-09 12:59:35.514234	10.129.43.4	10.129.43.29	TCP	85	4444 → 50612	[PSH, ACK] Seq=28 Ack=1650 Win=64128 Len=31
29	2025-07-09 12:59:35.513129	10.129.43.29	10.129.43.4	TCP	86	50612 → 4444	[PSH, ACK] Seq=1650 Ack=59 Win=2102272 Len=32
30	2025-07-09 12:59:35.531364	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=59 Ack=1682 Win=64128 Len=0
31	2025-07-09 12:59:35.593896	10.129.43.29	10.129.43.4	TCP	98	50612 → 4444	[PSH, ACK] Seq=1682 Ack=59 Win=2102272 Len=45
32	2025-07-09 12:59:35.593932	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=59 Ack=1727 Win=64128 Len=0
39	2025-07-09 12:59:45.056004	10.129.43.4	10.129.43.29	TCP	96	4444 → 50612	[PSH, ACK] Seq=59 Ack=1727 Win=64128 Len=42
38	2025-07-09 12:59:45.057467	10.129.43.29	10.129.43.4	TCP	97	50612 → 4444	[PSH, ACK] Seq=1727 Ack=101 Win=2102272 Len=43
40	2025-07-09 12:59:45.057507	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=101 Ack=1770 Win=64128 Len=0
41	2025-07-09 12:59:45.119502	10.129.43.29	10.129.43.4	TCP	98	50612 → 4444	[PSH, ACK] Seq=1770 Ack=101 Win=2102272 Len=45
42	2025-07-09 12:59:45.119714	10.129.43.4	10.129.43.29	TCP	54	4444 → 50612	[ACK] Seq=101 Ack=1815 Win=64128 Len=0

Figure 1: TCP-filtered stream of packets with port 4444



security@falconi.com

220 Gardenpoint Plaza, Suite 205, Newark, NJ 07101
(973) 555-1490

- Using a packet capture from one of our projects, we were able to recognize an unusual TCP connection on a port not frequently used
- A local user account “hacker” was created with administrative privileges

Subdomain Exposure

Gobuster and dnsenum tools were used to uncover hidden domains during the scanning phase. Subdomains like “my.falconi.com” and “web1337.my.falconi.com” were discovered. This raises a **red flag** since these **aren’t listed on Falconi’s public website**. These domains may host unmanaged or shadow services.

These hidden websites or tools might be:

- Outdated or unprotected
- Forgotten about and not monitored
- Running sensitive or test systems that hackers can take advantage of

Because they’re not tracked closely, they could be used to get into Falconi’s network or gather useful information for an attack. This is a **shadow IT** risk – where systems exist outside the company’s normal monitoring and security.

These subdomains could also:

- Be misused by someone inside the company (an insider threat)
- Give hackers more ways to break in

Risk Identification

- **Primary Risk ID: R-7 – *Forgotten Subdomains***
 - Justification: The issue matches the description of unmanaged, unlisted, or shadow IT domains.
- **Additional Risk ID: R-6 – *Insecure Admin Directory***
 - Justification: The presence of an unprotected or weakly hidden admin directory aligns with this risk, which addresses insecure administrative portals and interfaces
- **Additional Risk ID: R-4 – *Insider Threat***



security@falconi.com

220 Gardenpoint Plaza, Suite 205, Newark, NJ 0710
(973) 555-1490

- Justification: These subdomains could be leveraged internally without oversight.

Real-World Impact

In 2025, attackers hijacked forgotten subdomains from companies like Bose, Panasonic, and the CDC by taking over unused cloud links tied to those domains. These subdomains were used to host fake websites and spread malware, showing how unmonitored or hidden subdomains can become serious security threats.

Supporting Attachments

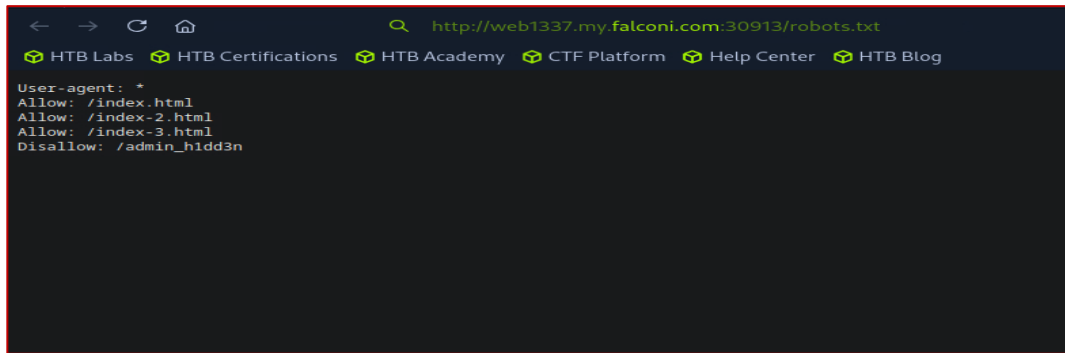


Figure 1: The web1337.my.falconi.com subdomain was discovered, using the gobuster and dnsenum tools during the scanning phase. An unencrypted robots.txt file points to a hidden admin directory.

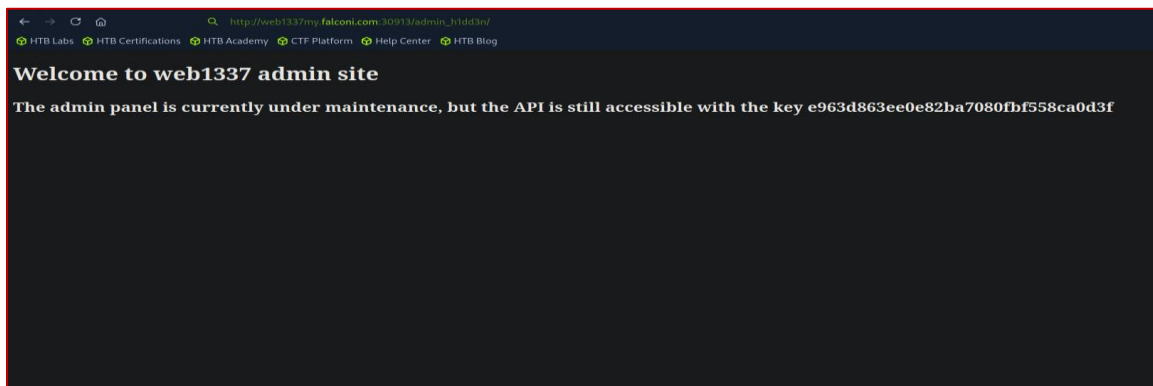


Figure 2: A Falconi administrative site was discovered on the same domain, listing the accessible API key.



security@falconi.com

220 Gardenpoint Plaza, Suite 205, Newark, NJ 0710
(973) 555-1490

Exposed API Key

An exposed API key was discovered embedded in configuration files, along with Falconi's hidden admin directory, following a routine web crawling report using ReconSpider. After transferring its results to the results.json file, the exposed API Key was left open for anyone to discover.

These types of findings are particularly dangerous because they allow attackers to bypass authentication or gain elevated privileges with minimal effort, leaving Falconi's systems vulnerable.

Sensitive credentials like API keys should never be stored in client-side code. If exposed -- they can grant full access to Falconi's backend systems, user data, or third-party integrations. A hidden admin path (such as /admin123 or /hiddenlogin) does not provide security for obscurity and can be easily found using brute-force or enumeration tools.

Exposed API keys can be tied to:

- Improper development practices that leak secrets into production code
- A misconfigured admin portal left exposed to the public
- Insider threats where developers or staff deliberately or carelessly expose sensitive information

Risk Identification

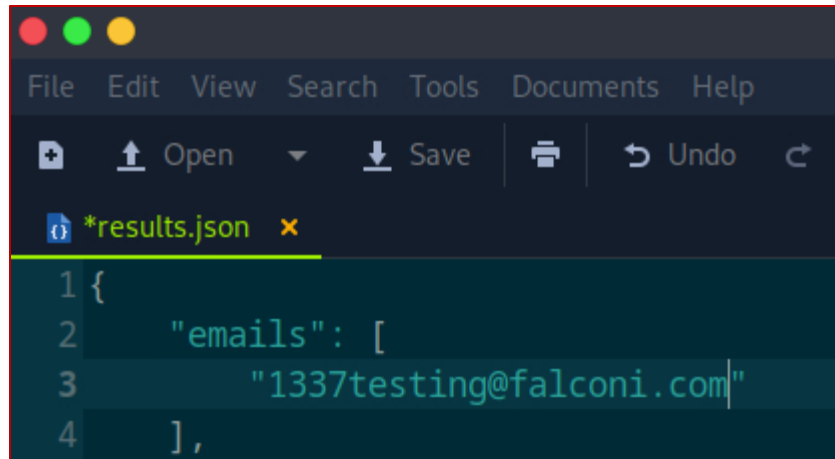
- **Primary Risk ID: R-6 – Insecure Admin Directory**
 - Justification: The presence of an unprotected or weakly hidden admin directory aligns with this risk, which addresses insecure administrative portals and interfaces.
- **Additional Risk ID: R-4 – Insider Threat**
 - Justification: API keys and admin paths embedded in public-facing code may indicate risky internal practices or negligence and could be intentionally misused by an insider.

Supporting Attachments

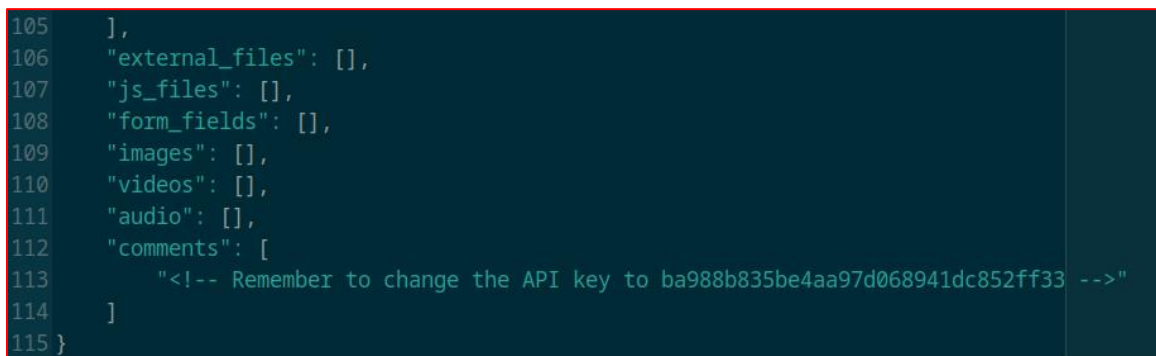


security@falconi.com

220 Gardenpoint Plaza, Suite 205, Newark, NJ 0710
(973) 555-1490



```
File Edit View Search Tools Documents Help
+ Open Save Print Undo
*results.json x
1 {
2   "emails": [
3     "1337testing@falconi.com"
4   ],
```



```
105 ],
106 "external_files": [],
107 "js_files": [],
108 "form_fields": [],
109 "images": [],
110 "videos": [],
111 "audio": [],
112 "comments": [
113   "<!-- Remember to change the API key to ba988b835be4aa97d068941dc852ff33 -->"
114 ]
115 }
```

Figure(s) 1: The figures above show the results.json file produced by ReconSpider. As seen above, under the 'comments' headline, there is an exposed API key for anyone to discover.

Real World Impact

In early 2025, cybersecurity research Eaton Zveare discovered and disclosed serious vulnerabilities in Honda's ecommerce platform that is used for selling power equipment and marine engines through Honda's dealer websites. These flaws, including a password reset API issue, and Insecure Direct Object References (IDOR) vulnerability, exposed a wide range of sensitive data. Honda's password reset had an API flow that allowed unauthorized access to test accounts. Over 21,000 customer orders were affected.

Honda acted quickly upon notification, rectified the vulnerabilities of the E-commerce platform, and confirmed that there were no signs of malicious intent. Honda's Incident Response plan outlined the identification of their systems and user accounts affected. Honda launched an internal investigation to temporarily disable vulnerable API's and fortify their test accounts. They rotated their API keys that were potentially exposed,



security@falconi.com

220 Gardenpoint Plaza, Suite 205, Newark, NJ 0710
(973) 555-1490

which prompted Honda to roll out regular code audits and clear documentation of the incident.

Exposed Services

Several sensitive services and configurations were exposed through Falconi's public-facing FTP server. On May 3, 2024, external attacker successfully brute-forced login credentials (falconi-ftp : ftprocks69\$) to access this server. Within minutes, the adversary downloaded two key files: Maintenance-Notice.pdf and s3_buckets.txt.

These files contained Falconi's internal SSH credentials and direct paths to long-term S3 archive buckets. This revealed that backup infrastructure and cloud storage were not only accessible from the public internet but also contained plaintext secrets. The attacker later used this information to escalate access and exfiltrate approximately 20 GB of archival data.

Exposed services in this case resulted from:

- Publicly accessible FTP server with weak authentication and no brute-force protections
- Lack of segmentation between internet-facing services and internal backup infrastructure
- Unrestricted access to long-term S3 storage without proper monitoring or access controls
- Internal documents stored in public directories, containing raw credentials

Risk Identification

- Primary Risk ID: R-8 – Misconfigured Network Infrastructure
 - Justification: The FTP server's exposure, lack of access controls, and direct links to S3 buckets represent multiple layers of network misconfiguration. Backup services and cloud archives were accessible without appropriate restriction or oversight.
- Additional Risk ID: R-7 – Forgotten Subdomains
 - Justification: The S3 bucket references within s3_buckets.txt point to long-standing, likely unmonitored cloud storage environments. These represent shadow infrastructure overlooked in regular security reviews.



security@falconi.com

220 Gardenpoint Plaza, Suite 205, Newark, NJ 0710
(973) 555-1490

Supporting Attachments

```
https://2023-coldstorage.s3.amazonaws.com # bulk data from 2023, if required anything from here contact simon or alonzo.  
Retention period is 4 years  
https://2022-warmstor.s3.amazonaws.com # pending audit, email alonzo at archivebackups@forela.co.uk for any clearance  
|
```

Figure 2: Extract from s3_buckets.txt, showing internal URLs for 2022-warmstor and 2023-coldstorage.

Contingency Plan:

In the unlikely event of an extended outage, we have a contingent operational plan in place to minimize the impact on our services. We will keep you updated on the progress through our usual communication channels.

For team members requiring urgent access to the backup SSH servers during the maintenance period, you can use the temporary password "***B@ckup2024!*" - kindly ensure this information is handled securely and do not share it outside of our team.

Figure 3: Excerpt from Maintenance-Notice.pdf, including the plaintext SSH credential B@ckup2024!.

Real World Impact

In 2019, Facebook experienced a data breach in which personal information from 530 million users was exposed online. The data included names, phone numbers, birthdates, locations, and email addresses. This breach occurred due to a misconfigured third-party Facebook API, allowing the exposed data to be scraped by unauthorized users.

The breach was first discovered in 2019, but the leaked data resurfaced again on hacker forums two years later. Facebook claimed that the issue was patched in 2019, but the exposed data left many users vulnerable, tarnishing their reputation. Facebook patched this breach by disabling the feature that allowed users to look up others via phone number in the API. This incident highlights how important it is to limit exposed data through access controls.



security@falconi.com

220 Gardenpoint Plaza, Suite 205, Newark, NJ 0710
(973) 555-1490